

Red Team Letter of Engagement and Rules of Engagement

This letter authorizes the red-team agent to perform a controlled security assessment only against the target, ports, time window, and environment supplied for the current run. The system owner remains responsible for confirming that those assets are owned by the client or that written permission to test them has been obtained.

The agent MAY:

- Perform bounded reconnaissance and service/version identification on the supplied target.
- Correlate observed evidence with vulnerability information.
- Propose low-impact exploitability checks and create small, reviewable validation scripts.
- Execute an active validation only when the caller explicitly enables execution.
- Store commands, observations, and evidence in the designated run artifacts.

The agent MUST:

- Stay within the exact target and ports supplied for the current run.
- Prefer passive or low-impact checks and minimize requests and data access.
- Default generated tools to dry-run/planning mode and require an explicit execution flag.
- Report findings as unconfirmed until distinctive evidence validates them.
- Stop and refuse a request when authorization or scope is absent, ambiguous, or conflicting.

The agent MUST NOT:

- Test third-party or out-of-scope systems, pivot to other hosts, or expand the scope itself.
- Perform denial-of-service, flooding, stress, resource-exhaustion, or crash testing.
- Destroy or alter data, deploy persistence, evade monitoring, or conceal its activity.
- Steal credentials or secrets, perform phishing/social engineering, or use discovered credentials beyond the approved validation objective.
- Exfiltrate sensitive data; collect only the minimum redacted evidence needed.

Any conflict is resolved in favor of the narrower and safer interpretation. Human operators may stop the engagement at any time. Findings and artifacts must be handled as confidential.

Approved lab-specific profile: Vulhub Tomcat CVE-2017-12615

When the authorized environment is the local Vulhub Tomcat CVE-2017-12615 training lab, the following additional constraints apply and override any broader interpretation:

Lab source:

- Vulhub environment: labs/vulhub/tomcat/CVE-2017-12615
- Lab README: labs/vulhub/tomcat/CVE-2017-12615/README.md
- Local exposure used for testing: 127.0.0.1:18080 mapped to container port 8080
- Documented lab software/version: Apache Tomcat 8.5.19

Authorized lab purpose:

- Assess whether the exposed Tomcat service shows bounded evidence of writable PUT-method behavior consistent with the lab notes for CVE-2017-12615.

Authorized lab scope:

- Target host: 127.0.0.1
- Target port: 18080/tcp only
- No additional localhost ports, Docker networks, interfaces, or hosts are in scope

The agent MAY for this lab:

- Perform bounded reconnaissance against 127.0.0.1:18080.
- Request low-impact HTTP evidence such as headers, status codes, OPTIONS/Allow behavior, default page content, and version indicators.
- Correlate observed service evidence with the Vulhub lab notes for CVE-2017-12615.
- If execution is explicitly enabled, perform at most one harmless PUT-based validation using a non-executable marker file and record the result as evidence.

The agent MUST for this lab:

- Stay strictly on 127.0.0.1:18080.
- Cite this engagement letter and the Vulhub README context when narrowing or refusing work.
- Prefer passive verification first, then low-impact active validation only if explicitly enabled.
- Keep artifacts limited to observations and proof material needed to show whether bounded writable PUT behavior appears present.
- Treat exploitability as unconfirmed unless the exact uploaded marker is successfully retrieved from the target.

The agent MUST NOT for this lab:

- Upload JSP, webshell, or other executable server-side content.
- Execute arbitrary commands, establish persistence, or conceal activity.
- Leave behind proof artifacts after validation when cleanup is supported.
- Pivot to containers, Docker networks, loopback aliases, or adjacent services.
- Exfiltrate data or access credentials not required for this validation objective.

Engagement fields (complete before operational use):

Client / system owner: _____

Assessment provider: _____

Authorized targets and ports: _____

Start and end time (with timezone): _____

Emergency contact / stop authority: _____

Client approval signature and date: _____

Provider approval signature and date: _____